BV'TECH
Securing the future

DOCUMENTAZIONE TECNICA

Anonimizzazione di documenti clinici

Servizio anonymization-pipeline - Piattaforma MIA, evoluzione C1

Cliente	AGENAS - Piattaforma MIA (Medical Information Access)
Versione	Ottobre 2026 - branch ref/backend
Destinatari	team di sviluppo, team piattaforma, referenti tecnici
Classificazione	Confidenziale

BV'TECH

SOMMARIO

1 Scopo e contesto
2 Architettura: due pod
3 Flusso di elaborazione
4 Server OCR
5 Rilevamento dei dati personali
6 Redazione e verifica fail-closed
7 API REST
8 Privacy, logging e KPI
9 Deploy, configurazione e avvio
10 Risultati e limiti noti

1 SCOPO E CONTESTO

anonymization-pipeline è il servizio della piattaforma MIA (AGENAS) che implementa il capitolo **C1 - Anonimizzazione** delle evoluzioni AI. Un medico carica un referto, una lettera di dimissione o una prescrizione (PDF nativo, PDF scansionato o foto); il servizio trova i dati personali e li rimuove dal file. Le pagine che contengono dati personali sono sostituite da un'immagine di se stesse con i riquadri neri dipinti sopra: impaginazione, colori e tabelle restano identici e un layer di testo invisibile le mantiene ricercabili. Le pagine senza dati personali restano come sono.

Principi di progetto

- **Fail-closed.** Ogni output è verificato prima di poter essere scaricato. Se la verifica fallisce, il documento è bloccato. Se il servizio NER non risponde, il job fallisce senza rilasciare nulla.
- **On-premise e open source.** Tutti i modelli girano nel cluster, su componenti con licenze permissive (pypdfium2, pypdf, LiteParse, RapidOCR con modelli PP-OCRv5).
- **Stateless.** Nessun database: i job vivono in memoria e i documenti in una cartella privata fino alla scadenza (TTL, 30 minuti di default).
- **Privacy by design.** Nessun testo, valore o nome di file nei log; URL con soli identificativi casuali; messaggi d'errore generici in italiano.

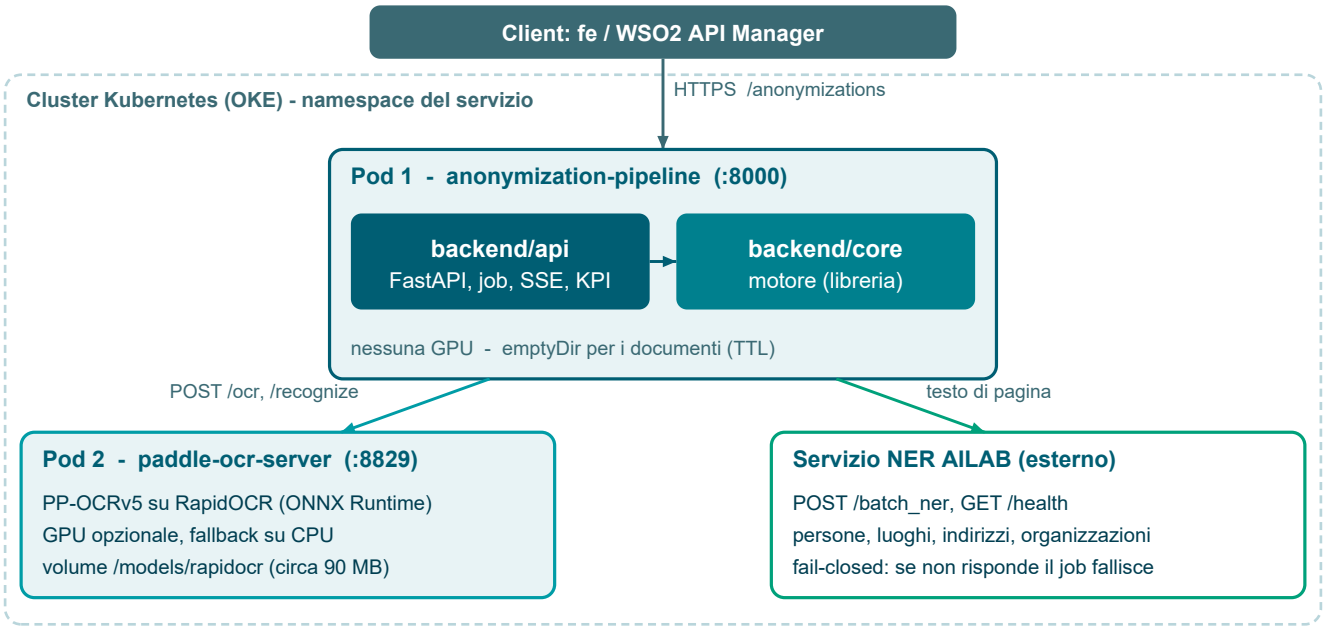
Due modalità

Modalità	Cosa fa	Output
accurate (default)	Pipeline completa: rilevamento su testo e pixel, redazione del PDF, verifica, revisione affiancata con modifiche manuali.	PDF anonimizzato + copia Word
fast	Stessi layer di testo e rilevamento testuale (regole, etichette, NER, propagazione), senza rilevatori visivi, senza redazione del PDF e senza controlli sui pixel.	Markdown con delimitatori di pagina, tabelle e segnaposto [IMMAGINE]

Confidenziale. Questo documento contiene informazioni riservate e non può essere riprodotto o diffuso senza autorizzazione.

2 ARCHITETTURA: DUE POD

Il sistema è composto da due deployable. Il **backend** espone l'API e contiene il motore di anonimizzazione; non carica modelli e non usa GPU. Il **server OCR** legge le pagine scansionate ed è l'unico componente che può usare una GPU. Il backend lo chiama via HTTP sul Service `paddle-ocr` dello stesso namespace. Il riconoscimento delle entità (NER) è delegato al servizio NER AILAB già in uso nella piattaforma.



Componente	Immagine / porta	Ruolo	Risorse
Backend (api + core)	anonymization-pipeline :8000	Upload, coda dei job, progresso SSE, anonimizzazione, verifica, download, eventi KPI	nessuna GPU; 1-4 CPU, 4-8 Gi (da rimisurare)
Server OCR	paddle-ocr-server :8829	PP-OCRv5 (detector server, recognizer latino) dietro l'API OCR di LiteParse	GPU opzionale (picco circa 4 GB per pagina); 1-2 CPU, 3-6 Gi
NER AILAB	servizio esistente	Entità su testo: persone, luoghi, indirizzi, ragioni sociali	gestito da AILAB

Struttura del repository

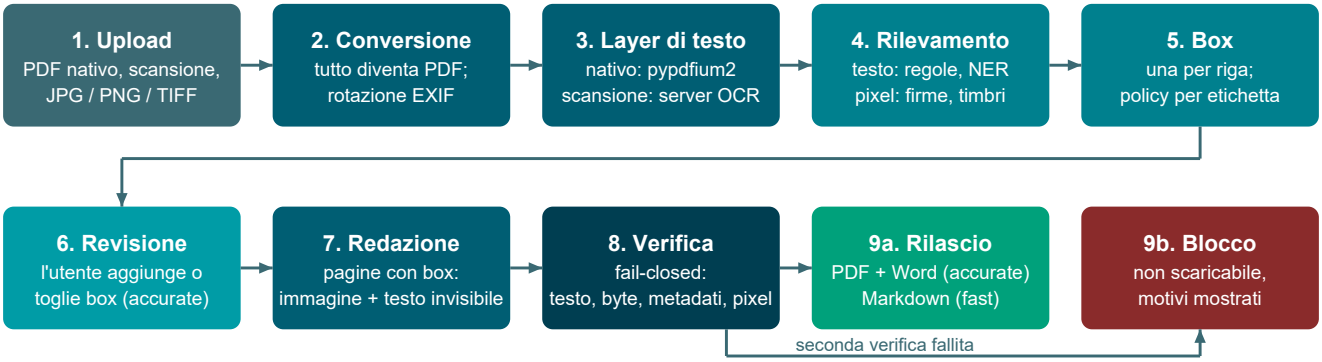
Una cartella per pod, più la valutazione (solo sviluppo, mai in un'immagine). Backend e valutazione formano un workspace uv: il motore non importa mai il servizio né un framework web (vincolo imposto da ruff), così può essere estratto da solo.

```
backend/                pod 1, immagine anonymization-pipeline
  Dockerfile            build di api + core (contesto: root del repository)
  api/                  servizio FastAPI: main, config, errors, privacy, api/, services/jobs.py
  core/                 motore: reader, detect/, pipeline, release, verify, export
ocr-server/             pod 2, immagine paddle-ocr-server (lock e Dockerfile propri)
evaluation/             CLI di valutazione sul dataset: just evaluate, just eval-compare
docs/  scripts/         documentazione, avvio locale
docker-compose.yml  justfile  .gitlab-ci.yml  pyproject.toml  uv.lock
```

Confidenziale. Questo documento contiene informazioni riservate e non può essere riprodotto o diffuso senza autorizzazione.

3 FLUSSO DI ELABORAZIONE

Il rilevamento lavora su testo semplice, la redazione lavora sul PDF. Il collegamento è il **layer di testo**: il testo della pagina in cui ogni carattere conserva il proprio riquadro. Uno span rilevato `(inizio, fine)` diventa un rettangolo per riga.



Layer di testo

- **Pagine native**: pypdfium2 legge il layer di testo del PDF con un riquadro esatto per carattere. Sono inclusi il testo invisibile (bianco, render mode 3), i valori dei campi modulo e le annotazioni visibili.
- **Pagine scansionate** (immagine a pagina intera o immagini oltre metà pagina, secondo LiteParse): pagina renderizzata a 300 DPI e letta dal server OCR, una box per parola. I margini laterali sono riletti ruotati di 90 gradi; pagine e righe capovolte sono rilette girate di 180 gradi.
- Una scansione con un layer OCR nascosto riceve entrambi i layer: anche il testo nascosto viene redatto.
- Le righe sono ricostruite dalla geometria, in ordine di lettura: le celle di tabella restano separate e un'etichetta precede il suo valore.
- **Caratteri in caselle** (codice fiscale o tessera sanitaria su moduli, "R S S M R A ...") sono uniti in una parola. Sulle scansioni le caselle sono trovate dalla rigatura del modulo (OpenCV), ripulite dalle macchie e rilette come parola unica dal server OCR (`POST /recognize`).
- Le **immagini cliniche in scala di grigi** dentro pagine native (RX, TC, ecografie) restano visibili; il testo impresso nei pixel viene letto dal server OCR e redatto. Le foto a colori sono redatte per intero (FACE).

4 SERVER OCR

Il server (`ocr-server/`) espone PP-OCRv5 su RapidOCR (ONNX Runtime) dietro l'API OCR di LiteParse. Il contratto è fissato da test su entrambi i lati (`backend/core/OCR_CONTRACT.md`). Il testo letto non viene mai registrato.

Endpoint	Input	Risposta
POST /ocr	PNG della pagina, header X-Render-DPI	{"results": [{text, bbox, confidence, polygon}]}, una voce per parola, coordinate in pixel; l'ordine dei punti del polygon indica la direzione di lettura
POST /recognize	PNG di una sola riga o parola	{"text", "confidence"}: solo riconoscimento, usato per le caselle dei codici
GET /health	-	200 quando i modelli sono caricati, altrimenti 503

- Il classificatore di orientamento delle righe di RapidOCR è disattivato: girava righe dritte di 180 gradi, che venivano poi lette come rumore e scartate insieme ai dati personali.
- Una pagina con confidenza media sotto 0,8 viene riletta girata di 180 gradi; la lettura girata è tenuta solo se è sicura e più ricca. Su una pagina dritta, una riga sotto 0,5 viene riletta girata (etichetta incollata al contrario); se la rilettura non è sicura la riga è scartata come rumore.
- I modelli (circa 90 MB) sono letti da `/models/rapidocr`: il cluster non ha accesso a internet, quindi il volume va popolato prima del primo avvio.

Confidenziale. Questo documento contiene informazioni riservate e non può essere riprodotto o diffuso senza autorizzazione.

5 RILEVAMENTO DEI DATI PERSONALI

Prima la recall: basta un rilevatore per redigere. I rilevatori testuali e visivi lavorano in parallelo e i loro risultati sono uniti; gli span sovrapposti confluiscono nell'etichetta più specifica.

Rilevatore	Cosa trova
Regole di formato	Codice fiscale con checksum (più un pattern tollerante all'OCR), tessera sanitaria, telefoni italiani ed esteri, email, IBAN, URL con token personali, date di nascita, età, indirizzi, CAP + comune, iscrizioni professionali (OMCeO), NRE, campi DICOM
Etichetta - valore	Il valore dopo circa 60 gruppi di etichette italiane e inglesi ("Cognome:", "N. accettazione", "Prenotazione CUP", "Medico curante"), con la forma attesa del valore (nome, luogo, indirizzo, identificativo, data, telefono)
NER AILAB	Persone, luoghi, indirizzi, ragioni sociali via POST /batch_ner, una richiesta per pagina. Gli offset sono riallineati sul testo originale. Retry su timeout e 502/503/504, poi fail-closed
Filtro eponimi	Per occorrenza: "segno di Giordano" resta, "Sig. Giordano" va redatto. Circa 400 eponimi, 50 scale cliniche, 200 nomi commerciali di farmaci, santi nei nomi di strutture
Propagazione	Ogni nome e identificativo trovato è cercato in tutto il documento: spaziato, incollato, a capo, con iniziali, con confusioni OCR (0/o, 1/l, 5/s), stesso schema di numerazione
Rilevatori visivi	Codici a barre e QR (zxing), firme e timbri (immagini incorporate, disegni vettoriali, inchiostro non spiegato dall'OCR, timbri con cornice o inchiostro colorato), foto a colori

Tassonomia

Etichette	Tipo	Redatte di default
PERSON, FISCAL_CODE, HEALTH_CARD, ID_DOCUMENT, DATE_OF_BIRTH	testo	sì
ADDRESS, LOCATION, PHONE, EMAIL	testo	sì
MEDICAL_RECORD, PRESCRIPTION_ID, PROFESSIONAL_ID, IBAN, URL	testo	sì
AGE, DATE (date cliniche), ORGANIZATION	testo	no: quasi-identificatori, configurabili
SIGNATURE, STAMP, BARCODE, QRCODE, FACE, HANDWRITING	visivo	sì

Le date cliniche, l'età e le strutture sanitarie vengono rilevate ma lasciate visibili di default; si redigono impostando `ANONPIP_REDACT_CLINICAL_DATES`, `ANONPIP_REDACT_AGE` e `ANONPIP_REDACT_ORGANIZATIONS`.

Confidenziale. Questo documento contiene informazioni riservate e non può essere riprodotto o diffuso senza autorizzazione.

6 REDAZIONE E VERIFICA FAIL-CLOSED

Redazione

- **Propagazione**: ogni occorrenza di un valore redatto riceve un riquadro, anche dove il rilevamento non l'aveva trovata (incollata a un'etichetta, spezzata dall'OCR, in un'intestazione fax).
- **Pagine con riquadri**: renderizzate a 200 DPI senza perdita, riquadri dipinti sopra, sostituite dall'immagine. Della pagina originale sopravvivono solo i pixel; un layer di testo invisibile con le parole non coperte la mantiene ricercabile.
- **Pagine senza riquadri**: copiate come sono.
- **Ricostruzione del file** con pypdf a partire dalle sole pagine: nessun metadato, XMP, segnalibro, struttura, modulo, allegato, JavaScript, annotazione o versione incrementale precedente.
- Le aree disegnate a mano sono estese al riquadro completo di ogni carattere che toccano.

Controlli prima del rilascio

#	Controllo
1	Nessun testo originale leggibile sotto un riquadro (testo orizzontale e verticale)
2	Nessun testo fuori dall'area visibile della pagina
3	Nessun valore redatto nel testo di output, nei byte decompressi del file o nei metadati
4	Nessuna annotazione rimasta
5	Pagine renderizzate identiche fuori dai riquadri (tolleranza ANONPIP_VERIFY_PIXEL_TOLERANCE)
6	Nessun valore redatto nell'export Word (o nel Markdown in modalità fast)

Seconda passata. Se un controllo fallisce, il valore ancora presente viene coperto dove il controllo lo ha trovato, le pagine senza riquadri che hanno fallito vengono anch'esse appiattite e il file è ricostruito e verificato di nuovo. Il risultato riporta le pagine appiattite (`flattened_pages`).

> **Blocco.** Un documento che fallisce anche la seconda verifica non è scaricabile (409 `VERIFICATION_FAILED`) e le ragioni sono mostrate a chi lo ha caricato. Una modifica manuale rende subito il job non verificato: nulla è scaricabile finché la nuova versione non supera tutti i controlli.

Confidenziale. Questo documento contiene informazioni riservate e non può essere riprodotto o diffuso senza autorizzazione.

7 API REST

Prefisso `/anonymizations`. La modalità si sceglie all'upload con `?mode=accurate|fast`; un'azione dell'altra modalità risponde 409 `MODE_NOT_SUPPORTED`. Endpoint di piattaforma: `/healthz`, `/readyz`, `/version`.

Metodo e path	Cosa fa	Modalità
POST /anonymizations	Upload multipart (file) e avvio; 202 con {id, pages, size, mode}	entrambe
GET /{id}	Stato del job; include il risultato a fine elaborazione	entrambe
GET /{id}/events	Server-Sent Events: un messaggio per avanzamento, poi lo stato finale	entrambe
POST /{id}/cancel	Interrompe al passo successivo; file cancellati	entrambe
GET /{id}/preview	Manifest della revisione affiancata: pagine, riquadri, etichette, versione	accurate
GET /{id}/pages/{original|anonymized}/{n}	PNG della pagina (dpi 50-200, default 110)	accurate*
POST /{id}/edits	{add, remove, restore, search}: redazione e verifica, nessun nuovo rilevamento	accurate
GET /{id}/download/{pdf|docx}	Documento anonimizzato, solo se verificato e senza modifiche in corso	accurate
GET /{id}/download/md	Testo anonimizzato in Markdown, solo se verificato	fast
DELETE /{id}	Cancellazione immediata	entrambe
GET /labels	Tassonomia con i nomi italiani	-

* La pagina originale è disponibile in entrambe le modalità, quella anonimizzata solo in accurate.

Revisione affiancata (contratto con il frontend)

- Il client segue `/events` (o interroga `GET /{id}`) fino a `status: done`, poi legge `/preview`: originale a sinistra, anonimizzato a destra.
- `rect` e dimensioni pagina sono in punti PDF con origine in alto a sinistra: si scalano con `larghezza_immagine_px / width`. I riquadri non contengono testo.
- Il revisore disegna un'area per redigerla o clicca un riquadro per toglierlo o ripristinarlo (`POST /edits`); `version` e gli URL delle pagine cambiano a ogni modifica, quindi nessuna cache obsoleta.

Codici di errore

Codice	HTTP	Quando
UNSUPPORTED_FORMAT / FILE_TOO_LARGE / TOO_MANY_PAGES	415 / 413 / 413	upload non valido
UNREADABLE_DOCUMENT / PASSWORD_PROTECTED	422	file illeggibile o cifrato
TOO_MANY_JOBS	429	coda piena (ANONPIP_MAX_JOBS)
JOB_NOT_FOUND	404	id sconosciuto, scaduto o cancellato nel frattempo
JOB_NOT_READY / MODE_NOT_SUPPORTED	409	job non concluso o modifica in corso / azione dell'altra modalità
VERIFICATION_FAILED	409	verifica fail-closed non superata
NER_UNAVAILABLE / SERVICE_UNAVAILABLE	503 / error_code	dipendenza giù: riprovare più tardi
PROCESSING_FAILED	error_code	errore di elaborazione non classificato

Confidenziale. Questo documento contiene informazioni riservate e non può essere riprodotto o diffuso senza autorizzazione.

8 PRIVACY, LOGGING E KPI

Ciclo di vita dei documenti

- Un job alla volta (un worker per pod); anche le modifiche passano dallo stesso worker.
- I documenti vivono in una cartella privata (permessi 0700) solo finché il job esiste; sono cancellati alla scadenza (`ANONPIP_JOB_TTL_MINUTES`), su DELETE, su cancel e allo spegnimento.
- I job sono in memoria: con più di una replica l'ingress richiede session affinity.
- Gli URL contengono solo identificativi casuali di 32 caratteri esadecimali. I download hanno un nome generico (`documento_anonimizzato.pdf`), perché il nome originale può contenere il nome del paziente.
- Il testo di ogni pagina esce dal pod solo verso il servizio NER AILAB, all'interno del cluster; il pod OCR riceve immagini di pagina, non scrive su disco e non registra il testo letto.

Regole di logging

Livello / categoria	Regola
Mai, in nessun ambiente	Codici fiscali in chiaro, nomi, email, JWT, chiavi, header grezzi, body di richiesta o risposta, stringhe di connessione, input di un errore di validazione
Contenuto di debug	Testo inserito dall'utente solo in locale e staging, a livello DEBUG, tramite redact_user_text e con ANONPIP_EXTENDED_LOG_CONTEXT=true. In prod sempre <redacted>
Identificativi personali	hash_identifier (SHA-256, stessa normalizzazione di authz) o mask_identifier (R***U)
Rete di sicurezza	PiiRedactingFilter maschera i codici fiscali in tutto ciò che arriva su stdout, traceback e uvicorn compresi
Errori di elaborazione	Solo il tipo di eccezione: i messaggi possono contenere testo del documento

Eventi KPI (contratto con KPI-dashboard)

Formato `nome_evento {json}` su stdout, inviato a Loki da Grafana Alloy. Nomi e chiavi non si rinominano; ogni evento è coperto da un test che verifica anche l'assenza di PII.

Evento	Chiavi
anonymization_job_created	job_id, pages, size_kb, source_format, mode
anonymization_completed	job_id, pages, scanned_pages, boxes, values_by_label, verified, edits, seconds_total, timings, mode
anonymization_edited	job_id, added, removed, restored, search_hits, verified, seconds
anonymization_failed	job_id, error (tipo di eccezione)
anonymization_cancelled / anonymization_job_deleted	job_id / job_id, reason (user, expired)

Confidenziale. Questo documento contiene informazioni riservate e non può essere riprodotto o diffuso senza autorizzazione.

9 DEPLOY, CONFIGURAZIONE E AVVIO

Gli sviluppatori non modificano i repository Flux (`oke-staging`, `oke-prod`): consegnano la scheda `docs/DEPLOY_HANDOVER.md` al team piattaforma, che crea namespace, manifest, image policy e Kustomization. Il servizio non ha segreti né database.

	Pod backend	Pod OCR
Immagine	harbor.agenas.oci/agenas/anonymization-pipeline	harbor.agenas.oci/agenas/paddle-ocr-server
Build	docker build -f backend/Dockerfile --target runtime .	docker build --build-arg OCR_EXTRA=gpu ocr-server
Probe	/healthz (liveness), /readyz (503 finché OCR e NER non rispondono)	/health (503 finché i modelli non sono caricati)
Repliche	1, oppure 2+ con session affinity	1
Storage	emptyDir per ANONPIP_WORK_DIR	volume dei modelli su /models
Esposizione	Ingress interno / WSO2	solo Service interno paddle-ocr

Variabili principali

Variabile	Default	Note
ANONPIP_ENVIRONMENT	prod	il più conservativo: redazione log attiva, DEBUG e OpenAPI spenti
ANONPIP_OCR_SERVER_URL	vuoto	http://paddle-ocr:8829 in cluster; vuoto = /readyz 503
ANONPIP_NER_URL	vuoto	URL interno del servizio NER AILAB; vuoto = /readyz 503
ANONPIP_NER_RETRIES / _TIMEOUT_SECONDS	2 / 30	retry su timeout e 502/503/504, poi il job fallisce
ANONPIP_MAX_UPLOAD_MB / MAX_PAGES / MAX_JOBS	30 / 50 / 20	limiti dell'upload e della coda
ANONPIP_JOB_TTL_MINUTES	30	dopo la scadenza i documenti sono cancellati
OCRSRV_DEVICE	auto	GPU se disponibile, altrimenti CPU; gpu = termina senza GPU
OCRSRV_GPU_MEM_LIMIT_MB	0	tetto opzionale della memoria GPU (almeno 4500 se usato)

Rilascio

Feature branch, poi MR verso `test`: la CI esegue lint, tipi, test e Sonar per i soli pacchetti toccati, costruisce `YYYY.MM.DD-test.<epoch>` e Flux rilascia in staging. Dopo la validazione, MR da `test` a `main`: tag `YYYY.MM.DD` e rilascio in produzione. L'immagine OCR si ricostruisce solo quando cambia `ocr-server/`.

Avvio locale

Comando	Cosa fa
just start	dipendenze, server OCR sull'host (GPU se presente), API sulla prima porta libera, pagina /docs
just ocr-server + just dev	i due processi separati, come i due pod (API con reload)
just up / just down	docker compose con i container app e paddle-ocr
just models	verifica che server OCR e servizio NER rispondano
just lint / just test-cov	ruff + ty; test con copertura minima 80% per pacchetto
just evaluate / just eval-compare	valutazione su dataset/ (report in reports/evaluation.md); confronto tra due run

Confidenziale. Questo documento contiene informazioni riservate e non può essere riprodotto o diffuso senza autorizzazione.

10 RISULTATI E LIMITI NOTI

Misure con `just evaluate` sull'insieme di valutazione: 200 documenti sintetici (326 pagine), ciascuno come PDF nativo, scansione e scansione con layer OCR nascosto, per 600 PDF. 185 documenti in italiano e 15 in inglese, con trappole mirate: testo bianco, metadati, note cancellate, cognomi uguali a eponimi, codici in caselle, fax. Ground truth esatta, generata dallo stesso seed del documento. Valutazione del 22/10/2026, servizio NER AILAB, server OCR su GPU RTX 5070 laptop (8 GB).

Metrica	Nativo	Scansione	Scansione + layer OCR
Recall (box, PII obbligatori)	0,940	0,918	0,933
Precision (box)	0,954	0,926	0,872
F1 (box)	0,947	0,922	0,902
Accuracy (parola)	0,986	0,960	0,951
AP@0.5 / mAP@0.5	0,663 / 0,674	0,595 / 0,582	0,519 / 0,568
PII nascosti trapelati	1 / 324	n/a	0 / 324
Eponimi redatti per errore	65 / 415	77 / 415	108 / 415
Documenti che superano la verifica	200 / 200	200 / 200	200 / 200
Secondi per pagina	0,75	2,54	2,67

Per tipo: codice fiscale 99% / 94% / 96% (nativo / scansione / scansione + layer), tessera sanitaria 100%, persone 96-97%, codici a barre, QR, URL e IBAN 97-100%. I più deboli sono i numeri interni di pratica (MEDICAL_RECORD, 74-79%), i documenti d'identità sulle scansioni (70%) e la scrittura a mano (0 su 21, coperta dalle modifiche manuali). La recall è la metrica di sicurezza (un valore mancato è una fuga); la precision misura la sovra-redazione.

Limiti noti

- Dati personali scritti a mano sulle scansioni non sono rilevati: li coprono le modifiche manuali.
- Il servizio NER AILAB può mancare o redigere in parte nomi che sostituisce come eponimi ("Corti", "Vittoria"), nomi stranieri ed elenchi fitti di pazienti. Se il servizio è giù, i job falliscono.
- Le caselle dei codici sono trovate solo con rigatura scura e continua: griglie grigio chiaro o rosse e caselle tratteggiate restano alla lettura OCR di pagina.
- Le pagine con riquadri diventano immagini: restano ricercabili tramite il layer invisibile, ma non sono più testo vettoriale e i documenti nativi crescono di circa il 45%.
- Testo ruotato di angoli diversi da 90 e 180 gradi non è gestito. Input DOCX/TXT non supportato; la modalità reversibile (mappatura cifrata) è fuori ambito.

Confidenziale. Questo documento contiene informazioni riservate e non può essere riprodotto o diffuso senza autorizzazione.